

Rapport d'Analyse des Bugs

SAE 2.04 - Application e-commerce telephones

Analyse n°1 | Date : 26/03/2026

Ce rapport presente les resultats d'une analyse statique complete du projet realisee par 4 agents specialises couvrant le backend, le frontend, la base de donnees et les liens entre les couches.
Les erreurs sont classees par severite.

Backend	11 critiques 6 hautes 6 moyennes 4 basses
Frontend	3 critiques (ressources manquantes) 8 hautes 15+ moyennes
Base de donnees	3 critiques 7 hautes/moyennes tables manquantes
Liens inter-couches	7 desalignements critiques entre frontend / backend / BD

1. BACKEND (Flask / Python)

Erreurs critiques

Severite	Erreur / Description	Fichier	Ligne
CRITIQUE	Identifiants MySQL en dur (user=root, password=secret)	connexion_db.py	8-10
CRITIQUE	Secret key Flask triviale et previsible	app.py	24
CRITIQUE	Mode debug=True actif (expose traceback + console interactive)	app.py	102
CRITIQUE	Route /base/init non protegee - reinitialise toute la BD sans auth	fixtures_load.py	12
CRITIQUE	IDOR : un client peut voir les commandes d'un autre utilisateur	client_commande.py	136-150
CRITIQUE	mycursor.execute(sql, commande_id) - string au lieu de tuple -> crash	admin_commande.py	69
CRITIQUE	client_historique_add() brisee (SQL vide, parametre reassigne en interne)	client_liste_envies.py	40-50
CRITIQUE	SQL vides dans client_commentaire.py : toutes les routes commentaires/notes	client_commentaire.py	60-129
CRITIQUE	SQL vides dans client_coordonnee.py : aucune logique adresse implementee	client_coordonnee.py	12-100
CRITIQUE	SQL vides dans admin_commentaire.py et admin_type_telephone.py	admin_*.py	-
CRITIQUE	SQL vides dans admin_declinaison_telephone.py (4 routes vides)	admin_declinaison.py	12-81

Erreurs hautes

Severite	Erreur / Description	Fichier	Ligne
HAUTE	Stock decremente a l'ajout panier (pas a la commande) - double vente possible	client_panier.py	59-64
HAUTE	Race condition sur le stock entre lecture et decrementation	client_panier.py	23-64
HAUTE	int(request.form.get('quantite')) sans try/except -> crash si valeur invalide	client_panier.py	17
HAUTE	Routes add/delete liste envies en methode GET au lieu de POST	client_liste_envies.py	12,19,26
HAUTE	Suppression commentaires sans verif que ca appartient a l'utilisateur	client_commentaire.py	81-91
HAUTE	Pas de validation des entrees (prix, stock, IDs non verifiees comme numeriques)	admin_telephone.py	71-79

2. FRONTEND (HTML / CSS / Jinja2)

Ressources manquantes (critiques)

Severite	Erreur / Description	Fichier	Ligne
CRITIQUE	perso_admin.js reference mais fichier inexistant -> erreur 404 console	layout_admin.html	25
CRITIQUE	star_rating.css reference mais fichier inexistant -> styles etoiles absents	telephone_details.html	4
CRITIQUE	Fonction loadFile() appelee via onchange mais non definie nulle part	add/edit_telephone.html	20,35

Erreurs hautes

Severite	Erreur / Description	Fichier	Ligne
HAUTE	Formulaires imbriques <form> dans <form> (HTML invalide - donnees non soumises)	telephone_details.html	100-110
HAUTE	 au lieu de - balise non reconnue, style non applique	declinaison_telephone.html	28
HAUTE	{{ commentaire.__dict__ }} affiche en production - expose internes Python	show_avis.html	48
HAUTE	Filtre safe sur donnees non validees (labels, values) -> XSS potentiel	dataviz_etat_1.html	72,76
HAUTE	Attribut value sur <input type='file'> - inoperant pour des raisons de securite	edit_telephone.html	35
HAUTE	minlength/maxlength sur <input type='number'> - attributs invalides (utiliser min/max)	add_adresse.html	21
HAUTE	Classe form-select appliquee sur <input type='text'> (destine aux <select>)	add_type_article.html	17
HAUTE	Champ email avec type='text' au lieu de type='email' - pas de validation HTML5	signup.html	22

Erreurs moyennes (selection)

Severite	Erreur / Description	Fichier	Ligne
MOYENNE	Labels sans attribut for ou for ne correspondant a aucun id d'input	signup.html	18-24
MOYENNE	Lien 'Mot de passe oublie' avec href='' - ne mene nulle part	_nav.html	27
MOYENNE	Dropdown-toggle sur au lieu d'un <button> (semantique incorrecte)	_nav_*.html	8,16
MOYENNE	CSS : br { color: blue; } - br est vide, la couleur n'a aucun effet	mes_styles.css	3
MOYENNE	type='button' sur des elements <a> - attribut invalide sur les liens	_nav_*.html	17-24
MOYENNE	Code commente en masse (40+ lignes Bulma) laisse en production	login.html	40-69

3. BASE DE DONNEES (MySQL)

Erreurs critiques de schema

Severite	Erreur / Description	Fichier	Ligne
CRITIQUE	Colonne id_ligne_panier absente du schema mais utilisee partout dans le code	sae_sql.sql.txt	78-86
CRITIQUE	Tables entieres manquantes : commentaire, note, historique, adresse, fournisseur, marque	sae_sql.sql.txt	-
CRITIQUE	Aucune transaction lors de la creation de commande - donnees partielles en cas d'erreur	client_commande.py	79-103

Erreurs hautes et moyennes

Severite	Erreur / Description	Fichier	Ligne
HAUTE	Aucun index sur les 8 colonnes de cles etrangeres - JOINS tres lents	sae_sql.sql.txt	43-86
HAUTE	Stock decremente a l'ajout panier et non a la commande - incoherence metier	client_panier.py	59-64
HAUTE	Pas de contrainte CHECK (stock >= 0) ni CHECK (quantite > 0) - valeurs negatives	sae_sql.sql.txt	54,72,81
MOYENNE	nom dans utilisateur sans NOT NULL - valeur NULL acceptee	sae_sql.sql.txt	22-23
MOYENNE	Pas de contrainte UNIQUE sur libelle dans etat, couleur, type_telephone	sae_sql.sql.txt	30,35,40
MOYENNE	marque et fournisseur en VARCHAR dans telephone au lieu de FK vers tables dediees	sae_sql.sql.txt	51-52
MOYENNE	poids DECIMAL(5,2) - max 999.99g, insuffisant pour certains appareils	sae_sql.sql.txt	46
MOYENNE	Normalisation : meme modele duplique par couleur, stock duplique par variante	sae_sql.sql.txt	119-134

4. LIENS ENTRE COUCHES (desalignements Frontend / Backend / BD)

Severite	Erreur / Description	Fichier	Ligne
CRITIQUE	Formulaire envoie 'idCommande' (camelCase) mais backend attend 'id_commande' -> None	show.html:50 admin_commande.py:62	/ 50/62
CRITIQUE	Template accede telephone_commande[0].id - cle inexistante dans le dict SQL	show.html:50 admin_commande.py:42	/ 50/42
CRITIQUE	URL /client/telephone/details/123 (path) mais route attend ?id_article=123 -> 404	panier_telephone.html:36 client_commentaire.py:14	/ 36/14
CRITIQUE	Template affiche commande.nbr_telephones mais SQL retourne nbr_articles (3 noms!)	show.html:71 client_commande.py:119	/ 71/119
CRITIQUE	SELECT id_ligne_panier dans le code mais colonne absente de la table ligne_panier	_panier.html:47 client_panier.py:32+	/ 47/32+
CRITIQUE	declinaison_telephone.html envoie ?id_telephone= mais backend attend ?id_article=	declinaison_telephone.html:9 client_commentaire.py:14	/ 9/14
HAUTE	SELECT types sans alias AS libelle mais template accede type.libelle -> dropdown vide	add_telephone.html:27 admin_telephone.py:53	/ 27/53

5. PRIORITES DE CORRECTION

1 - IMMEDIAT	Ajouter id_ligne_panier AUTO_INCREMENT a ligne_panier OU revoir la logique (PK composite)
2 - IMMEDIAT	Corriger idCommande -> id_commande dans le template admin des commandes
3 - IMMEDIAT	Uniformiser les URLs /client/telephone/details (path param vs query param)
4 - IMMEDIAT	Creer les tables manquantes (commentaire, adresse, etc.) et implementer les SQL vides
5 - URGENT	Deplacer la decrementation du stock de l'ajout panier vers la creation de commande
6 - URGENT	Ajouter les transactions SQL sur la creation de commande (BEGIN / ROLLBACK / COMMIT)
7 - URGENT	Creer les fichiers JS/CSS manquants (perso_admin.js, star_rating.css, loadFile())
8 - SECURITE	Sortir les identifiants BD dans des variables d'environnement (.env)
9 - SECURITE	Changer la secret_key Flask pour une valeur aleatoire forte
10 - SECURITE	Desactiver debug=True et proteger la route /base/init par un role admin

Rapport genere automatiquement par analyse statique multi-agents - SAE 2.04 - 26/03/2026